Software Seguro

```
root@software-seguro:~# ./start_course.sh
```

Clase 3: Herramientas de Intercepción y Enumeración Activa

Curso Profesional de Ciberseguridad Web y Ethical Hacking

Objetivos de la Sesión

Entender los pilares de la ciberseguridad,

Interceptar, automatizar y analizar peticiones HTTP

para auditar la lógica de aplicaciones web.

¿Qué es un Proxy?

Un proxy es, fundamentalmente, un intermediario o delegado en una red informática. En lugar de que tu computadora hable directamente con el servidor de destino (ejemplo: Google), tu computadora le habla al proxy, el proxy le habla a Google, recibe la respuesta, y te la entrega a vos.

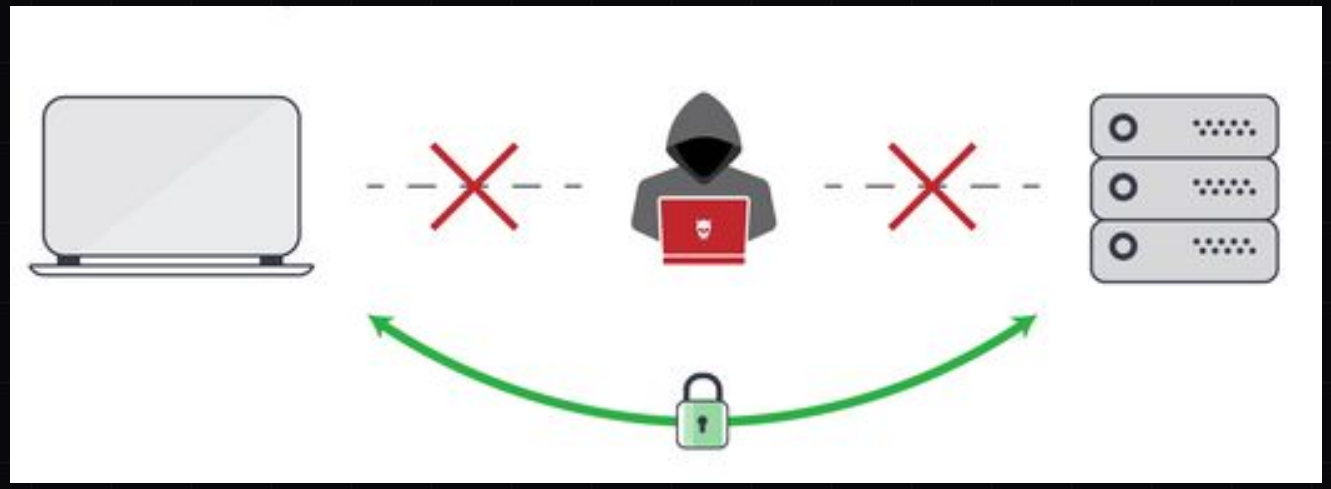
> **Forward Proxy (Proxy de salida):** Filtra o anonimiza la salida de una red interna hacia Internet (ej: el proxy del colegio o de la empresa que te bloquea redes sociales).

> **Reverse Proxy (Proxy inverso):** Protege a los servidores (ej: Cloudflare). Recibe las peticiones de Internet y las reparte a los servidores internos ocultando su verdadera IP.

> **Proxy de Intercepción (Nuestro foco hoy):** Diseñado específicamente para que el analista pueda frenar, leer y editar cada paquete antes de que siga su camino.

Man-in-the-Middle (MitM)

Es un ataque o técnica donde una entidad maliciosa (o un auditor) se ubica secretamente entre las dos partes que intentan comunicarse.



Configurar nuestro Proxy





Módulos Esenciales de Burp Suite

Proxy & History

Punto de captura principal. Almacena la bitácora completa de peticiones y respuestas, permitiendo filtros por MIME type, código HTTP y alcance definido.

Repeater

Permite aislar una petición específica (Ctrl + R) para modificar valores de forma iterativa y observar respuestas inmediatas sin recargar la web.

Intruder

Motor de automatización y parametrización (Ctrl + I). Sustituye marcadores por listas de palabras para pruebas de fuerza bruta y enumeración.

Repeater: Auditoría Controlada

Casos de Uso Principales

Pruebas rápidas de hipótesis durante la auditoría de APIs y controladores web.

- Manipulación de IDs numéricos para forzar accesos.
- Inyección de Headers como X-Forwarded-For.
- Testeo de inputs anómalos (JSON malformado, carácteres especiales).

Modos de Ataque en Intruder

MODO DE ATAQUE	MARCADORES Y LISTAS	COMPORTAMIENTO / USO TÍPICO
Sniper	1+ posiciones | 1 lista	Prueba la lista en una posición a la vez. Ideal para probar inyecciones SQL/XSS en un único parámetro.
Battering Ram	Múltiples pos. | 1 lista	Inserta el mismo payload en todas las posiciones a la vez. Útil si usuario y contraseña deben coincidir.
Pitchfork	Múltiples pos. | Varias listas	Itera en paralelo (L1:1 con L2:1, L1:2 con L2:2). Ideal para probar pares de credenciales ya conocidos.
Cluster Bomb	Múltiples pos. | Varias listas	Prueba todas las combinaciones posibles (Fuerza Bruta real). Cruza cada usuario con cada contraseña.

Fuerza bruta

El ataque de fuerza bruta es un método exhaustivo que busca vulnerar un sistema probando sistemáticamente combinaciones de datos (credenciales, claves criptográficas, identificadores o rutas) hasta dar con la correcta.

En el contexto web, la fuerza bruta consiste en enviar solicitudes HTTP repetidas hacia puntos de entrada específicos para descubrir valores válidos o adivinar secretos:

Espacio de búsqueda: Se apoya en la probabilidad y la capacidad de cómputo del atacante frente a la entropía (complejidad) del secreto.
Canales web típicos: Formularios HTML tradicionales (POST /login), APIs REST (/api/v1/auth), endpoints GraphQL, mecanismos de recuperación de contraseña o campos de códigos temporales (PINs/OTP).

Vectores de impacto: Compromiso de cuentas (Account Takeover), exposición de endpoints ocultos, evasión de restricciones de acceso y denegación de servicio (DoS) por saturación de base de datos.(Nuestro foco hoy): Diseñado específicamente para que el analista pueda frenar, leer y editar cada paquete antes de que siga su camino.

Ejemplos

Pasamos de la teoría a la práctica

Asignación para el Hogar

Resolver y enviar los objetivos del Módulo I: Fundamentos: Herramientas de Intercepción y Enumeración Activa

Ingresar a la plataforma de Software Seguro, en las opciones les aparecera el curso “Curso Profesional de Ciberseguridad Web y Ethical Hacking”, dentro del curso tienen los distintos módulos con sus objetivos que deberán enviar antes de la próxima sesión

¿Preguntas?

Fin de la Sesión 3.

https://softwareseguro.com.ar